



Sky: Diamond PAU Deployment Scripts & Deployment Review

Security Review

Cantina Managed review by:

Christoph Michel, Lead Security Researcher

M4rio.eth, Lead Security Researcher

June 10, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
2.1	Scope	3
3	Findings	4
3.1	Low Risk	4
3.1.1	Deploy script does not check the beacon is empty before wiring it	4
3.2	Informational	4
3.2.1	Missing view from <code>quoteTransfer</code>	4
3.2.2	Makefile deploy targets can run with wrong config and leave partial deployments	4
3.2.3	Deploy script does not check that admin is not <code>address(0)</code>	5

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Sky Protocol is a decentralised protocol developed around the USDS stablecoin.

From Jun 8th to Jun 10th the Cantina team conducted a review of [diamond-pau-deploy](#) on commit hash [90df5687](#) (tag [v1.0.0-beta.0](#)). The team identified a total of **4** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	0	1
Gas Optimizations	0	0	0
Informational	3	0	3
Total	4	0	4

The Cantina Managed team reviewed Sky's [diamond-pau-deploy](#) holistically on commit hash [90df5687](#) (tag [v1.0.0](#)) and concluded that all findings were addressed and no new vulnerabilities were identified.

2.1 Scope

The security review had the following components in scope for [diamond-pau-deploy](#) on commit hash [90df5687](#) (tag [v1.0.0-beta.0](#)):

The diamond PAU deployment scripts and deployed contract configuration.

3 Findings

3.1 Low Risk

3.1.1 Deploy script does not check the beacon is empty before wiring it

Severity: Low Risk

Context: `DeployFacetsAndWire.s.sol#L116-L133`

Description: `DeployFacetsAndWire.run()` loads `.beacon` from the config JSON and assumes it is a fresh Beacon administered only by the deployer:

```
// NOTE: Assuming beacon admin is deployer
```

It does not check the deployer is the sole admin or that `beacon.integrations().length == 0`.

If the supplied Beacon already has an extra admin, that admin remains after the script revokes only the deployer. If it already has a stale integration id with different selectors, that integration remains because `setIntegration()` only clears prior config for the same id.

Recommendation: Consider deploying the Beacon as part of the deploy script.

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.2 Informational

3.2.1 Missing view from `quoteTransfer`

Severity: Informational

Context: `ExternalFacetInterfaces.sol`

Description: `ILayerZeroFacetExternal.layerZero_quoteTransfer` is declared as non-view, but the wired implementation `LayerZeroFacet.quoteTransfer` is `view`. The function gained `view` in the audit fixes (`c741e32`, #199), and the external interface was not updated to follow.

Recommendation: Add `view` to the external declaration so it matches the wired facet.

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.2.2 Makefile deploy targets can run with wrong config and leave partial deployments

Severity: Informational

Context: `Makefile`

Description:

- The `deploy-facets-and-wire-mainnet-*` targets set only `ENV`, but `ScriptTools.loadConfig(name)` prefers `FOUNDRY_SCRIPT_CONFIG_TEXT` and `FOUNDRY_SCRIPT_CONFIG`. A leftover shell variable can make `ENV=production` load staging or arbitrary config.
- `ScriptTools.exportContract(name, ...)` still honors `FOUNDRY_EXPORTS_NAME`, so output can be written under a different slug than the selected `ENV`.
- Broadcast targets run all facet deploys, 25 `setIntegration()` calls, `grantRole()`, and `revokeRole()` without `--slow`. A mid-sequence broadcast failure can leave a partially wired Beacon while later queued transactions remain eligible to execute.
- Dry-run targets omit `--broadcast`, but the script still sets:

```
vm.setEnv("FOUNDRY_EXPORTS_OVERWRITE_LATEST", "true");
```

A dry-run can overwrite `wire-facets-mainnet-{env}-latest.json` with simulated addresses.

- `PostDeployFacetsAndWireBase.t.sol` reads `ETHERSCAN_API_KEY`, while `foundry.toml` uses `MAINNET_API_KEY`, so `make test-postdeploy-mainnet` needs a second env var.

Recommendation:

Unset the override env vars and add `--slow` in the broadcast targets:

```
deploy-facets-and-wire-mainnet-production:
  env -u FOUNDRY_SCRIPT_CONFIG_TEXT -u FOUNDRY_SCRIPT_CONFIG -u FOUNDRY_EXPORTS_NAME \
    ENV=production forge script
    ↪ script/mainnet/DeployFacetsAndWireMainnet.s.sol:DeployFacetsAndWireMainnet \
    --sender $(ETH_FROM) --account deployer --broadcast --slow --verify --rpc-url
    ↪ $(MAINNET_RPC_URL)
```

Also:

- Split final admin handoff into a separate checked target, or assert all expected integrations before `grantRole()` and `revokeRole()`.
- Make dry-runs use a distinct slug or disable latest overwrites.

```
if (vm.envOr("DRY_RUN", false)) {
  vm.setEnv("FOUNDRY_EXPORTS_OVERWRITE_LATEST", "false");
}
```

- Use the same API-key variable in tests and `foundry.toml`

```
string memory apiKey = vm.envOr("ETHERSCAN_API_KEY", string(""));
if (bytes(apiKey).length == 0) apiKey = vm.envString("MAINNET_API_KEY");
```

Sky: Acknowledged.

Cantina Managed: Acknowledged.

3.2.3 Deploy script does not check that admin is not `address(0)`

Severity: Informational

Context: `DeployFacetsAndWire.s.sol#L114-L133`, `wire-facets-mainnet-production.json#L4-L5`, `AccessControl.sol#L122-L124`, `AccessControl.sol#L183-L187`

Description: `DeployFacetsAndWire.run()` reads `.admin`, checks only `deployer != admin`, then grants Beacon admin to `admin` and revokes the deployer:

```
address admin = config.readAddress(".admin");
...
require(deployer != admin, "DeployFacetsAndWire/deployer-must-differ-from-admin");
beacon.grantRole(beacon.DEFAULT_ADMIN_ROLE(), admin);
beacon.revokeRole(beacon.DEFAULT_ADMIN_ROLE(), deployer);
```

The pinned OpenZeppelin `grantRole()` path does not reject `address(0)`. If `.admin` is zero, the script leaves `address(0)` as the only `DEFAULT_ADMIN_ROLE` member.

Recommendation: Add an `address(0)` check.

Sky: Acknowledged.

Cantina Managed: Acknowledged.